



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-07
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-07 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk

1. Executive Summary

CVE-2026-43958 is a stack-based buffer overflow in `rrdcached`, the caching daemon shipped with RRDtool. Public CVE, NVD, GitHub Advisory, and Red Hat sources agree that a local attacker who can connect to the `rrdcached` socket can trigger the flaw by sending an oversized `CREATE` request, causing a daemon crash and potentially achieving code execution in the daemon context.

The practical exposure is narrower than an internet-facing RCE. This is a local attack path tied to deployments that expose `rrdcached` over a local or network-accessible socket and permit untrusted users or tenants to issue `CREATE` requests. Environments that use RRDtool only as an offline graphing utility without `rrdcached`, or that tightly restrict socket access to trusted monitoring components, have materially lower risk.

2. Vulnerability Metadata

Field	Value
CVE	`CVE-2026-43958`
Product	RRDtool / `rrdcached`
Affected component	`rrdcached` `handle_request_create()` request-processing path
Weaknesses	`CWE-121 Stack-based Buffer Overflow`; Red Hat bug material also references `CWE-787 Out-of-bounds Write`
CVSS v3.1	`7.8 / HIGH`
CVSS vector	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
Attack precondition	ability to connect to the `rrdcached` socket and send a crafted oversized `CREATE` request
Primary vendor/assigner in the public CVE record	Red Hat
Public disclosure date in the CVE record	`2026-06-01`

3. Source Review & Confidence

Source	Contribution	Confidence
Reviewed source	Microsoft Update Guide mirrored publication of CVE-2026-43958 on 2026-06-07 and provided the intake reference used to op	Useful intake pointer, but not the richest technical source for final client-facing conclusions.
Reviewed source	Canonical CVE JSON 5 record assigns the issue to Red Hat, describes a local stack-based buffer overflow in `rrdcached`,	Highest-confidence canonical vulnerability record reviewed for this task.
Reviewed source	NVD repeats the same vulnerability description, CVSS vector, and CWE-121 classification and marks the item as awaiting N	Strong secondary normalization source for scoring and reference consistency.

Reviewed source	GitHub Advisory `GHSA-pgh2-hfvj-4q69` mirrors the CVE text, severity, CWE, and reference set and provides EPSS context.	Strong secondary advisory source; no extra package-version detail beyond the public CVE text.
Reviewed source	Red Hat Bugzilla identifies the vulnerable function as `rrdcached` `handle_request_create()` and describes exploitation	Best technical source reviewed for the exact vulnerable code path and fix shape.
Reviewed source	Debian tracker marks bullseye, bookworm, trixie, fork, and sid package versions as vulnerable and shows no Debian fixed	High-value downstream exposure source, but distro status may change quickly and should be rechecked
Reviewed source	The `v1.10.3` source contains `MAX_CREATE_AV` and `Too many DS/RRA` guard logic in `handle_request_create()`, while `v1.	Strong technical corroboration, but consumers should still validate which downstream package version

Primary-source confidence is high on the core issue: Confidence remains high for denial-of-service impact and moderate-to-high for code-execution potential because public sources consistently state it is possible, but the reviewed material does not include a fully public end-to-end exploitation write-up demonstrating reliable arbitrary code execution.

4. Vulnerability Details

`rrdcached` accepts remote management-style commands over a configured socket so clients can create and update round-robin database files without direct disk writes in every transaction. In the vulnerable path, `handle\_request\_create()` parses tokens from a `CREATE` command and stores `DS:` and `RRA:` arguments in a fixed-size argument array.

Red Hat's bug-tracker material indicates the vulnerable implementation accepted unbounded `DS:` / `RRA:` argument growth into a fixed stack buffer. A crafted request with more than the supported number of definitions could therefore write past the intended bounds and corrupt stack memory.

Public downstream patch material shows the fix pattern clearly:

- introduce a constant maximum argument count (`MAX\_CREATE\_AV 128`)
- reject oversized `DS:` / `RRA:` definition lists
- return an explicit error such as `Too many DS/RRA definitions (max 128)` instead of continuing into unsafe memory writes

This makes the issue best understood as a parser/command-handler memory-corruption flaw in `rrdcached`, not a generic RRDtool file-format issue.

5. Attack Scenarios

1. A shared Linux monitoring host exposes the `rrdcached` UNIX socket to a broad local group so multiple service accounts can manage RRD creation.
2. A multi-tenant appliance or hosting environment enables `rrdcached` and allows semi-trusted users or extensions to issue RRDtool create operations through the daemon.
3. An operator exposes `rrdcached` on a TCP listener for convenience without strong network access controls, allowing a low-privilege foothold elsewhere on the network to reach the vulnerable command path.

In each case, the attacker does not need user interaction. They need only socket access and the ability to send a malformed oversized `CREATE` request.

6. Threat Landscape & Exploitation Status

- Public disclosure exists.
- Public advisory coverage exists across CVE, NVD, GitHub Advisory, Red Hat, Debian, and other downstream security trackers.

- CISA ADP enrichment currently records `Exploitation: none`, `Automatable: no`, and `Technical Impact: total` in the SSVC enrichment data reviewed for this task.
- No evidence was collected during this review showing CISA KEV inclusion or confirmed in-the-wild exploitation.
- The exploit path is still operationally relevant because `rrdcached` is often deployed on monitoring infrastructure that may aggregate sensitive operational data and run continuously.

7. Affected Products and Exposure

The strongest supportable statement is that affected exposure centers on deployments using `rrdcached`, not every host that merely has RRDtool installed.

Relevant exposure patterns:

- Monitoring stacks that enable `rrdcached` for performance or write-coalescing.
- Systems where the `rrdcached` UNIX socket is writable by multiple local users, services, or containers.
- Deployments that expose `rrdcached` beyond localhost, whether intentionally or through weak binding/firewall choices.
- Downstream Linux distributions that have not yet shipped a fixed package. Debian tracker data reviewed on 2026-06-08 still lists vulnerable package versions with no Debian fixed version recorded.

Reduced-risk patterns:

- RRDtool installations that do not run `rrdcached`.
- Hosts where only a tightly scoped trusted service account can access the daemon socket.
- Environments already shipping a patched upstream/downstream build that includes the `MAX\_CREATE\_AV` guard.

8. Mitigation and Workarounds

Priority actions:

4. Patch to a build that includes the `handle\_request\_create()` bounds check fix. Source inspection indicates RRDtool tag `v1.10.3` contains the guard logic, but defenders should validate their vendor package changelog rather than assuming tag parity with distribution packages.
5. Restrict access to the `rrdcached` UNIX socket using filesystem permissions and least-privilege group membership.
6. Avoid exposing `rrdcached` over TCP unless there is a hard operational requirement; if TCP is necessary, place it behind strict network ACLs and trusted-management segmentation.
7. Run `rrdcached` as an unprivileged user/group so a successful crash or code-execution event lands in the narrowest possible context.
8. Review whether `CREATE` operations actually need to be available to all clients; reducing who can create new RRDs lowers abuse potential.

9. Detection Engineering

Reliable network or signature-based detection is limited because this is a local socket/daemon command issue. Detection should focus on service exposure, process telemetry, and package inventory:

Signal	Telemetry Source	Analytic Goal
Inventory hosts running `rrdcached` and identify whether the service is enabled, which socket type it exposes, and which users/groups can access that socket.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Alert on `rrdcached` crashes, repeated restarts, segfaults, or abnormal exits.	Application logs, service metrics, EDR / crash telemetry	Spot exploitation symptoms or instability
Monitor service managers and logs for repeated failed `CREATE` requests or	Asset inventory / service / security	Identify vulnerable systems, exposure, or

parser-style errors associated with `rrdcached`.	telemetry	suspicious follow-on activity
Flag package inventory showing vulnerable RRDtool/rrdcached builds on monitoring servers, collectors, and graphing appliances.	Asset inventory, SBOM, package management, CI/CD telemetry	Find vulnerable builds or packages
Review listening sockets to confirm `rrdcached` is not unintentionally exposed on TCP interfaces.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Asset and version discovery pivots for CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("dpkg -l", "rpm -qa", "apt list --installed", "pip show", "go version", "syft", "grype")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

10. Threat Hunting

Suggested hunt questions:

- Which systems run `rrdcached`, and what accounts or groups can write to its socket?
- Are any `rrdcached` instances bound to non-local addresses or reachable from semi-trusted internal segments?
- Have there been recent daemon crashes, restart loops, or core dumps involving `rrdcached`?
- Do any local users, containers, or automation jobs issue unusual bursts of `CREATE` requests or create RRDs with abnormally large numbers of `DS:` / `RRA:` definitions?
- Which Debian or Red Hat-family systems still carry unpatched RRDtool packages in operational monitoring roles?

10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2026-43958 rrdcached oversized CREATE request buffer overflow risk
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

11. MITRE ATT&CK Mapping

No ATT&CK technique is assigned with high confidence for this report. The available evidence supports local memory-corruption abuse against a daemon command interface, but it does not document a broader intrusion procedure, malware family, or operator playbook that would justify a precise ATT&CK mapping without over-claiming.

12. Validation / Lab Testing

This intake review validated the report against public advisory and source material rather than performing a fresh exploit reproduction. Analyst validation steps completed:

- Queried the CVE Project JSON 5 API for the canonical record.
- Queried NVD for the CVSS vector and status.
- Queried the GitHub Advisory API for GHSA metadata and EPSS context.
- Reviewed Red Hat Bugzilla metadata and proposal text describing the vulnerable `handle_request_create()` path.
- Reviewed Debian Security Tracker package status for downstream exposure.
- Compared upstream RRDtool source snapshots and confirmed that `v1.10.3` contains the `MAX_CREATE_AV` / oversized-definition guard logic while `v1.9.0` does not.

No Lost Boys Cyber proof-of-concept execution was performed as part of this draft review.

13. Recommended Actions Summary

Priority	Owner	Action
High	Security / Platform Owners	Identify all environments running <code>rrdcached</code> , not just RRDtool generally.
Critical	Platform / Application Owners	Patch or vendor the bounds-check fix on any host where untrusted or semi-trusted users can reach the daemon socket.
High	Security / Platform Owners	Restrict socket permissions and eliminate unnecessary TCP exposure.
High	SOC / Detection Engineering	Add monitoring for daemon crashes, restart spikes, and suspicious <code>CREATE</code> activity.
High	SOC / Detection Engineering	Treat this CVE as a high-severity local service-hardening issue for monitoring infrastructure rather than a broad internet-scale RCE.

14. References

9. Microsoft Security Response Center, `CVE-2026-43958`
10. CVE Project JSON 5 record for `CVE-2026-43958`
11. NVD entry for `CVE-2026-43958`
12. GitHub Advisory `GHSA-pgh2-hfvj-4q69`
13. Red Hat Bugzilla `2460932`
14. Debian Security Tracker entry for `CVE-2026-43958`
15. RRDtool upstream source, `src/rrd_daemon.c` , reviewed at tags `v1.10.3` and `v1.9.0`